



UNIVERSIDAD NACIONAL DE INGENIERÍA

"Ciencia y Tecnología al Servicio del País"

PUBLIC KEY CRYPTOGRAPHY STANDARD # 11
PKCS#11



PKCS#11 (CRYPTOKI)

- ES UNA API DE ARQUITECTURA ABIERTA QUE DEFINE UNA INTERFAZ LÓGICA PARA DISPOSITIVOS QUE MANTIENEN INFORMACIÓN CRIPTOGRÁFICA Y REALIZAN FUNCIONES DE PROCESAMIENTO, ABSTRAYENDO LAS PARTICULARIDADES FÍSICAS Y OPERATIVAS DEL HARDWARE DEL FABRICANTE.

DOS OBJETIVOS ARQUITECTÓNICOS IMPERATIVOS:

- INTEROPERABILIDAD
 - ESTANDARIZACIÓN DE LLAMADAS PARA QUE APLICACIONES AGNÓSTICAS OPEREN CON DISPOSITIVOS DE DIVERSOS PROVEEDORES.
- USO COMPARTIDO DE RECURSOS
 - ORQUESTACIÓN DE ACCESOS CONCURRENTES DE MÚLTIPLES APLICACIONES HACIA UNA INFRAESTRUCTURA DE HARDWARE DISTRIBUIDA.

ESTA INTERFAZ LÓGICA DEBE ENTENDERSE COMO UN MODELO DE MÁQUINA DE ESTADOS FINITOS QUE GOBIERNA LA INTERACCIÓN ENTRE EL SOFTWARE Y LOS COMPONENTES FÍSICOS QUE MATERIALIZAN EL MATERIAL CRIPTOGRÁFICO.

3



- LA ARQUITECTURA DE PKCS#11 DESVINCULA LA LÓGICA DE NEGOCIO DE LA MANIPULACIÓN DIRECTA DEL MATERIAL SENSIBLE MEDIANTE UNA JERARQUÍA DE ABSTRACCIÓN.
- UN COMPONENTE CRÍTICO ES LA GESTIÓN DE SESIONES, LAS CUALES REQUIEREN AUTENTICACIÓN MEDIANTE UNA CREDENCIAL (PIN) PARA ACCEDER A LOS OBJETOS PRIVADOS RESIDENTES EN EL TOKEN.

CONCEPTO	FUNCIÓN ARQUITECTÓNICA	IMPORTANCIA PARA LA SEGURIDAD
SLOTS	PUNTOS DE ACCESO LÓGICOS O CONECTORES FÍSICOS (SOCKETS).	PROPORCIONAN AISLAMIENTO EN EL PUNTO DE ENTRADA FÍSICO AL SISTEMA.
TOKENS	UNIDADES LÓGICAS (HSM, SMARTCARDS) QUE EJECUTAN OPERACIONES EN ENTORNOS SEGUROS.	GARANTIZAN QUE EL PROCESAMIENTO CRIPTOGRÁFICO NUNCA ABANDONE EL LÍMITE DE CONFIANZA DEL HARDWARE.
HANDLES	REFERENCIAS NUMÉRICAS O PUNTEROS OPACOS A OBJETOS INTERNOS.	AISLAMIENTO DE MATERIAL SENSIBLE: IMPIDEN QUE LA APLICACIÓN ACCEDA AL VALOR REAL DE LA LLAVE; SOLO SE OPERA MEDIANTE REFERENCIAS.

- EL USO DE HANDLES GARANTIZA QUE, INCLUSO SI LA MEMORIA DE LA APLICACIÓN ES COMPROMETIDA, EL ATACANTE SOLO OBTENDRÍA PUNTEROS INÚTILES FUERA DEL CONTEXTO DE LA SESIÓN AUTENTICADA POR EL PIN, SUPEDITANDO LA SEGURIDAD A LAS LEYES MATEMÁTICAS QUE RIGEN EL DISPOSITIVO.

4



- LÓGICA DE ATRIBUTOS Y REGLAS DE DEDUCCIÓN: LA SEGURIDAD EN PKCS#11 SE MODELA MEDIANTE REGLAS DE DEDUCCIÓN ALGEBRAICA. EL ACCESO Y USO DE UN OBJETO ESTÁN DICTADOS POR LA SATISFACIBILIDAD BOOLEANA DE UNA TUPLA DE ATRIBUTOS CONFIGURADOS EN EL SISTEMA.
- EN PKCS#11, EL COMPORTAMIENTO DE LOS OBJETOS ES INYECTADO MEDIANTE TEMPLATES (PLANTILLAS) DURANTE SU CREACIÓN O IMPORTACIÓN. LA SEGURIDAD RESIDE EN LA CORRECTA CONFIGURACIÓN DE ESTOS DESCRIPTORES ALGEBRAICOS.
- ANÁLISIS DE PERSISTENCIA ("STICKY ATTRIBUTES"): CIERTOS ATRIBUTOS COMO CKA_SENSITIVE SON INMUTABLES EN UNA SOLA VÍA; UNA VEZ ESTABLECIDOS EN TRUE, EL ESTÁNDAR PROHÍBE SU REVERSIÓN.
- ES VITAL DISTINGUIR CKA_SENSITIVE (ESTADO ACTUAL) DE CKA_ALWAYS_SENSITIVE (HISTORIAL DE INTEGRIDAD), EL CUAL SIRVE COMO PRUEBA DE QUE EL MATERIAL NUNCA HA SIDO EXPUESTO DESDE SU GENERACIÓN.
- DURANTE EL DESARROLLO, ESTOS ATRIBUTOS SON LOS PARÁMETROS FUNDAMENTALES QUE SE DEBE INYECTAR EN LOS MÓDULOS CRIPTOGRÁFICOS PARA MITIGAR RIESGOS LÓGICOS.



ATRIBUTO	TIPO DE DATO	PROPÓSITO	VALORES POSIBLES
CKA_CLASS	ENUMERADO	IDENTIFICA LA CLASE DEL OBJETO.	CKO_PUBLIC_KEY CKO_PRIVATE_KEY CKO_SECRET_KEY
CKA_KEY_TYPE	ENUMERADO	DEFINE EL ALGORITMO DE LA LLAVE.	CKK_RSA CKK_AES CKK_DES3
CKA_SENSITIVE	BOOLEANO	SI ES TRUE, IMPIDE LA SALIDA DE LA LLAVE EN TEXTO CLARO.	TRUE / FALSE
CKA_EXTRACTABLE	BOOLEANO	PERMITE LA EXPORTACIÓN CIFRADA (ENVUELTA).	TRUE / FALSE
CKA_ENCRYPT / CKA_DECRYPT	BOOLEANO	PERMISOS PARA CIFRADO Y DESCIFRADO DE DATOS.	TRUE / FALSE
CKA_SIGN / CKA_VERIFY	BOOLEANO	PERMISOS PARA FIRMAS Y VERIFICACIONES (MAC).	TRUE / FALSE
CKA_WRAP	BOOLEANO	PERMITE USAR LA LLAVE PARA ENVOLVER OTRAS LLAVES.	TRUE / FALSE
CKA_UNWRAP	BOOLEANO	PERMITE DESCIFRAR E IMPORTAR LLAVES ENVUELTAS.	TRUE / FALSE
CKA_ALWAYS_SENSITIVE	BOOLEANO	ATRIBUTO DE AUDITORÍA (SOLO LECTURA): INDICA SI LA LLAVE SIEMPRE HA SIDO SENSIBLE.	TRUE / FALSE
CKA_NEVER_EXTRACTABLE	BOOLEANO	ATRIBUTO DE AUDITORÍA (SOLO LECTURA): INDICA SI NUNCA HA SIDO EXPORTABLE.	TRUE / FALSE
CKA_TRUSTED	BOOLEANO	INDICA CONFIANZA; SOLO MODIFICABLE POR EL OFICIAL DE SEGURIDAD.	TRUE / FALSE



- DENTRO DE LA JAVA CRYPTOGRAPHY ARCHITECTURE (JCA), LA ELECCIÓN DEL PROVEEDOR DEFINE LA RESIDENCIA DEL MATERIAL SENSIBLE Y EL MODELO DE AMENAZA.
- EL ARQUITECTO DEBE COMPRENDER QUE SUNPKCS11 NO CONTIENE LOS ALGORITMOS; ES UN MENSAJERO QUE TRADUCE LLAMADAS JCA AL ESTÁNDAR NATIVO. LA SEGURIDAD NO DEPENDE DEL PASSWORD DEL ARCHIVO, SINO DE LA CONFIGURACIÓN DE ATRIBUTOS EN EL HARDWARE.

CARACTERÍSTICA	BOUNCY CASTLE (BC)	SUNPKCS11
NATURALEZA	BIBLIOTECA INTEGRAL DE SOFTWARE (IMPLEMENTA LOS ALGORITMOS).	ADAPTADOR/PUENTE (BRIDGE) LÓGICO HACIA HARDWARE NATIVO.
RESIDENCIA DE LLAVES	MEMORIA RAM DEL HOST (PROTEGIDAS POR ARCHIVOS FÍSICOS).	HARDWARE AISLADO (REFERENCIADAS MEDIANTE HANDLES).
INFRAESTRUCTURA	USA CONTENEDORES COMO BCFKS (AES-CCM Y PBKDF2).	REQUIERE UNA LIBRERÍA NATIVA (.SO O .DLL) Y EL KEYSTORE TIPO "PKCS11".
ABSTRACCIÓN	ARCHIVOS .P12 O .BKS MANEJADOS POR EL SO.	ACTÚA COMO UNA "VISTA" DEL HARDWARE; PUEDE USAR EL WRAPPER IAIK.
RESISTENCIA A ATAQUES	VULNERABLE A FUERZA BRUTA SOBRE EL KDF SI ES DÉBIL.	VULNERABLE A ATAQUES DE LÓGICA DE API EN EL DISPOSITIVO.

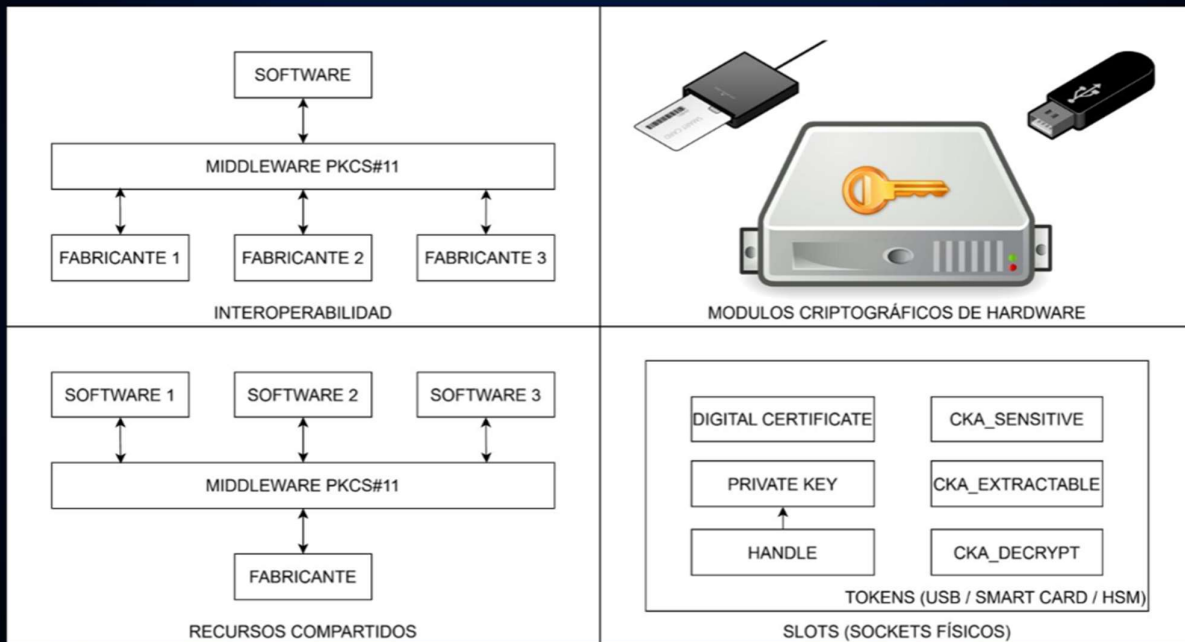
7



INCLUSO CON HARDWARE ROBUSTO, UNA CONFIGURACIÓN LÓGICA DEFECTUOSA PUEDE INVALIDAR TODA LA INFRAESTRUCTURA DE SEGURIDAD:

1. CONFLICTOS DE ROLES (WRAP/DECRYPT): UN FALLO CATASTRÓFICO OCURRE AL HABILITAR SIMULTÁNEAMENTE CKA_WRAP Y CKA_DECRYPT. MECANISMO DE FALLA: UN ATACANTE PUEDE TOMAR UNA LLAVE SENSIBLE ENVUELTA (TARGET), ENVIARLA A LA FUNCIÓN C_DECRYPT COMO SI FUERAN DATOS NORMALES, Y EL TOKEN LA DEVOLVERÁ EN TEXTO PLANO.
2. KEY CONJURING (CONJURO DE LLAVES): SE REFIERE A LA GENERACIÓN NO AUTORIZADA DE LLAVES MEDIANTE LA MANIPULACIÓN MALINTENCIONADA DE LAS FUNCIONES DE IMPORTACIÓN DE MATERIAL CRIPTOGRÁFICO.
3. ATAQUES DE LLAVE "TROJAN": UN ATACANTE IMPORTA UNA LLAVE DE EMPAQUETADO (WRAP) CUYA CLAVE CONOCE, PARA LUEGO "ENVOLVER" Y EXTRAER LEGALMENTE UNA LLAVE SENSIBLE RESIDENTE EN EL TOKEN.
4. DEBILITAMIENTO DE ALGORITMOS: OCURRE CUANDO SE PERMITE QUE LLAVES DE ALTA ENTROPÍA (EJ. 3DES) SEAN PROTEGIDAS POR ALGORITMOS O LONGITUDES DE LLAVE INFERIORES (EJ. RC2 DE 40 BITS).
5. LECTURA DIRECTA (DEFECTO DE IMPLEMENTACIÓN): OCURRE DURANTE UNA LLAMADA A *GetAttribute* DONDE UNA IMPLEMENTACIÓN DEFECTUOSA IGNORA EL FLAG CKA_SENSITIVE Y REVELA EL VALOR DE LA LLAVE.

8



UNIVERSIDAD NACIONAL DE INGENIERÍA

¡MUCHAS GRACIAS!